DEV-16 · Lost, Stolen or Compromised Device Response

One number to call, and what happens in the first hour.

Field	Value
Document ID	DEV-16
Version	1.0 · Known Good edition, by Kevin Zelman
Catalogue domain	C. Device Usage
Operating tier	Tier 2 — Advanced Technical Services acts; Tier 4 authorises remote wipe and declares incidents.
Review cycle	Annually, and after every use.

1. Purpose

A device goes missing perhaps a handful of times a year, which is exactly why nobody remembers what to do. This document is short enough to follow while somebody anxious is on the phone.

2. What the person does

> **Tell the service desk immediately. That is the whole ask.**
>
> Not after looking for it again. Not after the weekend. Not after deciding whether it counts as lost.
>
> Nobody is in trouble for losing a device. Losing one is an accident; not reporting it turns an accident into an exposure. The service desk's first question will be whether you are all right, particularly if it was taken from you.
>
> Contact the service desk by email, phone or in person. If it is out of hours and the device held CONFIDENTIAL data, say so in the subject line so it is picked up first.

3. The first hour

1. Establish the facts: which device, when it was last seen, where, whether it was taken or mislaid, and whether the person was present.
2. Look up the device in inventory: asset tag, class, primary user, and — critically — its encryption and escrow position (§4).
3. Establish what was on it. Not what should have been — what was. Ask about local files, and check the classification of anything the person had access to (M365-15).
4. Protect the account before the device. Revoke sessions and refresh tokens on the person's account; a signed-in session on a stolen laptop is more immediately useful to a thief than the disk is.

5. Mark the device non-compliant and block it in Conditional Access, so it cannot be used to reach organization resources even if somebody signs in.
6. Decide on remote wipe (§5).
7. Assess exposure. Where CONFIDENTIAL or RESTRICTED data may be readable, this is a GOV-03 incident and Tier 4 is informed now rather than after the device is dealt with.
8. Get the person working again — a loaner the same day (DEV-05). This matters more to them than anything above and should not wait for the investigation.

4. The question that determines everything

> **Was the disk encrypted, and is the key escrowed?**
>
> ENCRYPTED, KEY ESCROWED — the good case. The data is not readable by whoever has the device. This is a property-loss event, not a data event, and the response is proportionate to that.
>
> ENCRYPTED, NO KEY ESCROWED — the data is still not readable by a finder, but the organization also cannot recover it. Treat as property loss, and record it: this is another instance of the DEV-03 §2 gap and it should feed that count.
>
> NOT ENCRYPTED — assume the data is readable. This is a data exposure and it is a GOV-03 incident from the outset, not after assessment.
>
> UNKNOWN — treat as not encrypted until shown otherwise. Never assume in the favourable direction on this question.

This is the strongest practical argument for DEV-02 condition 3 and DEV-03: the difference between a lost laptop being a purchase order and being an incident is one setting, verified in advance.

5. Remote wipe

- Authorised by Tier 4 for an organization device. Tier 2 executes.
- Issued for a device that is stolen, or lost with no realistic prospect of recovery, or which held CONFIDENTIAL or RESTRICTED data.
- A wipe command executes when the device next connects. It may never execute — a wipe issued is not a wipe done, and the response should not assume it landed. Check and record whether it did.
- Do not delay account protection (§3 step 4) waiting for a wipe. Revoking sessions is immediate and certain; the wipe is neither.
- For a personal device, §6.

6. Personal devices

- The organization removes organization data from organization apps. It does not wipe personal property (DEV-07 §5).
- That removal is issued immediately on report and does not need Tier 4 authorisation, because it affects only organization data.

- Where the device carried the person's only MFA method, they will also need account recovery — verified per ACC-06, then a Temporary Access Pass (ACC-03 §5.4). Expect this and handle both in one contact rather than making them come back.
- Encourage them to use the device manufacturer's own find-and-lock service. That is theirs to run, and it is more capable on their device than anything the organization holds.

7. Theft, and the police report

- Theft is reported to site security, and to the police where it occurred off site. IT does not make that report on the person's behalf but should ask whether it has been made.
- Where a person was present during the theft, their welfare comes first and the device conversation waits. Site security and the person's manager or HR lead; IT supports.
- Record the crime reference where one exists. Insurance and any subsequent regulatory question will both want it.
- A pattern of thefts in one location is a Security matter and IT should say so rather than treating each as an isolated device loss.

8. If it comes back

1. Do not simply hand it back. A device that has been out of the organization's control is not trusted.
2. Confirm what happened to it while it was gone, as far as anybody can say.
3. Wipe and re-provision through Autopilot, whatever its apparent condition (DEV-15 §4).
4. Where it was recovered after a theft, and where any tampering is suspected, Tier 3 examines it before it returns to service — or it is retired. Physical access to a device is a strong position for an attacker and reimaging does not answer every question.
5. Close the incident record, noting the recovery and what was done.

9. Service levels

Activity	Commitment (per GOV-06)
Report received — sessions revoked and device blocked	P1 — within 30 minutes.
Escrow and encryption position established	Within the first hour.
Tier 4 wipe decision	Within 1 coverage hour of the facts being established.
Organization data removal from a personal device	P2 — within 4 coverage hours, no Tier 4 authorisation needed.
Loaner issued to the person	Same coverage day. They still have a job to do.
Unencrypted device lost	P1 — GOV-03 incident from the outset.

10. Records

Record	Held in	Retention
Report: device, circumstances, last seen, encryption position	Ticket	3 years
Account protection actions and times	Ticket	3 years
Wipe authorisation, issue, and whether it executed	Ticket + Tier 4 record	3 years
Exposure assessment and any incident declaration	Security record (GOV-03)	7 years
Crime reference	Ticket + asset register	7 years
Recovery and disposition if returned	Ticket + inventory	Life of the asset + 1 year

11. Related documents

ID	Title	Relationship
DEV-03	Disk Encryption & BitLocker Recovery Keys	§4 — the question that determines the whole response.
DEV-02	Device Compliance & Configuration Baseline	Condition 3 is what makes §4 answerable in the good direction.
DEV-01	Device Enrollment & Lifecycle	§10 inventory — without it, §3 step 2 is guesswork.
DEV-05	Loaner Device Issue, Support & Return	§3 step 8.
DEV-07	Personally-Owned Device Access Standard	§6.
DEV-15	Device Reassignment, Wipe, Retirement & Disposal	§8 — a returned device.
ACC-03	MFA Enrollment, Reset & Account Recovery	Where the lost device held the only method.
ACC-06	Identity Verification	Before restoring access to somebody who has lost their device.
M365-15	Data Classification & Handling	§3 step 3 — what was on it.
GOV-03	Security Incident Response	Where an exposure goes.

Appendix A — First-hour card

Keep at the desk. In order.

	Do	Note
1	Ask if the person is all right	Especially if it was taken from them. This comes first.
2	Facts: which device, when, where, taken or mislaid	Asset tag from inventory
3	ENCRYPTED? KEY ESCROWED?	§4. Unknown = treat as not encrypted.

	Do	Note
4	Revoke sessions and refresh tokens on their account	Immediate and certain — do this before anything about the device
5	Mark non-compliant, block in Conditional Access	Stops it reaching resources even if signed into
6	What was actually on it?	Ask. Check classification (M365-15).
7	Tier 4: remote wipe decision	A wipe issued is not a wipe done
8	Unencrypted, or CONFIDENTIAL/RESTRICTED at risk?	GOV-03 incident. Tell Tier 4 now.
9	Issue a loaner today	They still have a job. This matters to them more than steps 1–8.

Appendix B — What to tell the person

You are not in trouble	Losing a device is an accident. Reporting it quickly is the helpful thing, and you have done it.
What we are doing right now	Signing your account out everywhere and blocking the device, so nobody can use it to reach organization systems.
Whether your files are at risk	If the laptop was encrypted — and most are — the data is not readable by whoever has it. We will confirm and tell you either way.
Your account	Change your password, and if your only security method was on that device we will get you set up again — bring photo ID or join a short video call.
A replacement	We will get you a loaner today so you can keep working.
If it was stolen	Please report it to site security, and to the police if it happened off site. Let us know the reference when you have it.
If you find it	Tell us before you start using it again. We will need to reset it, which takes a little while but is straightforward.

Part of the Known Good SOP Catalog by Kevin Zelman, written for small IT shops, contractors and consultants, career-changers and help desk technicians. Adapt the names, tiers and times to your own shop: the times here are cushion, not a promise.